Guía del formador: MongoDB 8.0 · Índices y seguridad

Una sesión presencial de 180 minutos. Los cuatro manuales son material de estudio autónomo y ampliación; no deben leerse de principio a fin en clase. La sesión combina un experimento principal de indexación, cuatro índices especiales, TTL y un ensayo de autenticación y permisos. El perfil opcional TLS/X.509 puede ofrecerse como ampliación fuera de las tres horas.

1. Objetivo de aprendizaje y secuencia

Al terminar, el alumno sabrá justificar por qué un índice cambia el plan de acceso; diferenciar clave simple, compuesta, multikey, text, 2dsphere y hashed; interpretar nReturned, totalKeysExamined y totalDocsExamined; aplicar unique y TTL; y demostrar que un lector autenticado no puede escribir. También comprenderá qué infraestructura requieren TLS, X.509 y LDAP y qué significa proteger datos en reposo.

Tramo	Actividad	Referencia	Evidencia
00–15	Historia de la venta que tarda demasiado; índice B-tree y coste de escritura	Índices teoría 01–07	Predicción del plan sin índice
15–35	Carga previamente preparada de ventas y línea de base sin índice	Índices prácticas 02–05	COLLSCAN, contador de examinados
35–55	Índice simple; comparación A/B	Índices prácticas 06–07	IXSCAN, mismos resultados, menos trabajo
55–75	Prefijos compuestos, sorts y estrategia ESR	Índices teoría 08–14, prácticas 10–15	Justificación de diseño
75–100	Multikey, text, geoespacial y hashed	Índices prácticas 18, 20, 22, 23	Búsqueda por término y tipos de acceso
100–120	Unique, error E11000, TTL eventual	Índices prácticas 24–28	Error previsto y caducidad pendiente
120–135	Capas de seguridad y SCRAM frente a autorizaciones	Seguridad teoría 01–13	Distinción autenticación/autorización
135–160	Tres pruebas: anónimo rechazado, lector autorizado, escritura denegada	Seguridad prácticas 03, 06, 09	Error Unauthorized para insert
160–175	TLS, X.509, LDAP, cifrado en reposo y ediciones	Seguridad teoría 14–24	Tabla de capacidades y requisitos
175–180	Síntesis / preguntas	Seguridad práctica 27	Conclusión con evidencia y límite

Advertencia: es una secuencia intensa. Hay que tener Docker arrancado, datos cargados y la cuenta de seguridad creada **antes de empezar**. En la clase no se intenta cargar un millón de ventas en cada ordenador. Los laboratorios no incluidos arriba son ejercicios autónomos o extensiones.

2. Requisitos reales de infraestructura

Se necesita un ordenador con Docker Desktop o Docker Engine + plugin Compose funcionando, 8 GB de RAM como orientación, espacio libre para imágenes y volúmenes, PowerShell en Windows o terminal Bash en macOS/Linux. MongoDB Community 8.0 y mongosh se encuentran dentro de la imagen. MongoDB Compass es opcional.

El archivo `compose.yaml` configura **tres instancias independientes**, de las cuales dos intervienen en la ruta esencial: `mongo-indices` en `127.0.0.1:27017` sin autenticación (solo datos ficticios) y `mongo-seguridad` en `127.0.0.1:27018` con cuenta administrador y control de acceso. El tercer servicio `mongo-tls` escucha en `127.0.0.1:27019` y requiere generar certificados antes de arrancarlo; se utiliza únicamente en la ampliación.

Importante: la instancia libre no es un modelo productivo seguro; el aislamiento a localhost reduce el alcance pero no elimina riesgos locales. No publicar estos puertos en 0.0.0.0 ni compartir datos privados. Las cuentas y contraseñas incluidas en el ejemplo son sintéticas y no deben reciclarse.

3. Preparación en Windows (PowerShell)

Descomprime el repositorio y abre PowerShell **en la raíz del repositorio**. Ejecuta:

```
Copy-Item .env.example .env
docker version
docker compose config
docker compose up -d
docker compose ps
```

La primera descarga de imagen puede tardar según conexión. El siguiente comando **borra y recrea solamente** `curso_indices.ventas` en la instancia local de índices. Ejecútalo antes del curso, no mientras el alumnado observa el tiempo de carga:

```
docker compose exec -T mongo-indices mongosh --quiet --file /lab/01_cargar_ventas.js
docker compose exec -T mongo-indices mongosh --quiet --file /lab/00_preflight.js
docker compose exec -T mongo-indices mongosh --quiet --file /lab/02_antes.js
```

En este punto NO ejecutes `03_crear_indices.js` hasta la demostración del índice simple. El resultado sin índices secundarios debe conservarse como evidencia. La carga predeterminada es de 200.000 ventas; se puede subir a 1.000.000, preferiblemente en una máquina de demostración ya preparada:

```
docker compose exec -T -e VENTAS=1000000 mongo-indices mongosh --quiet --file /lab/01_cargar_ventas.js
```

Atención: al repetir la carga se eliminan los índices secundarios de `ventas`. Si ya has realizado la clase o creado índices, vuelve a ejecutar el bloque correspondiente. No borres los volúmenes del laboratorio para reiniciar solo una colección.

4. Preparación de la cuenta de seguridad

Este comando usa el administrador de demostración inicial creado por la imagen. El script prepara el documento ficticio y el lector con rol `read` en `curso_seguridad`:

```
docker compose exec -T mongo-seguridad sh -lc 'mongosh --quiet -u adminlab -p "$MONGO_INITDB_ROOT_PASSWORD" --
authenticationDatabase admin --file /lab/08_configurar_seguridad.js'
```

Comprueba después la existencia de la identidad y del documento desde una sesión administradora:

```
docker compose exec -T mongo-seguridad sh -lc 'mongosh --quiet -u adminlab -p "$MONGO_INITDB_ROOT_PASSWORD" --
authenticationDatabase admin --file /lab/11_verificacion_seguridad.js'
```

Y ejecuta la prueba **positiva y negativa** de permisos del alumno:

```
docker compose exec -T mongo-seguridad sh -lc 'mongosh --quiet -u lectorlab -p "$LAB_READER_PASSWORD" --
authenticationDatabase curso_seguridad --file /lab/09_comprobar_readonly.js'
```

En Linux o macOS sustituye únicamente `Copy-Item` por `cp .env.example .env`. Los comandos `docker compose` son iguales. En todos los casos los pasos de PowerShell/Bash están separados de los comandos internos de `mongosh`.

5. Demostración A/B de rendimiento

Primero enseña `02_antes.js` sobre el volumen recién cargado. Apunta de la salida: `nReturned`, `totalDocsExamined`, `totalKeysExamined`, etiqueta de etapa y milisegundos como dato secundario. El valor de `clienteId:4321` se encuentra en las ventas sintéticas.

Ejecuta la creación de índices, luego repite:

```
docker compose exec -T mongo-indices mongosh --quiet --file /lab/03_crear_indices.js
docker compose exec -T mongo-indices mongosh --quiet --file /lab/04_despues.js
docker compose exec -T mongo-indices mongosh --quiet --file /lab/05_tipos.js
docker compose exec -T mongo-indices mongosh --quiet --file /lab/10_verificacion_indices.js
```

`03_crear_indices.js` crea índices sobre `clienteId`, `{estado,fecha}`, `etiquetas`, `descripcion` de tipo text, `ubicacion` de tipo 2dsphere e `idGrupo` hashed. La prueba de `04_despues.js` utiliza `hint` deliberadamente en algunos ejercicios para comparar índices existentes. No conviertas hint en recomendación general de código de producción.

No anuncies una cifra fija de aceleración: en la mayoría de equipos el escaneo examinará una proporción grande de la colección y el índice de cliente leerá pocas coincidencias, pero los tiempos exactos cambian. **El resultado observable primario es la reducción del trabajo realizado.**

6. Unique y TTL: dos comportamientos que conviene explicar

```
docker compose exec -T mongo-indices mongosh --quiet --file /lab/06_unique_ttl.js
```

El script crea un índice unique sobre `cupones.codigo`, introduce una promoción e intenta repetir el mismo código. El fallo con E11000 es esperado: si el segundo documento entrara, habría un problema. Después crea una colección `sesiones` con índice TTL de `expireAfterSeconds:0` sobre fechas de expiración. Una sesión ya vencida es elegible; otra vence a los quince segundos; otra al cabo de una hora.

No hace falta detener la clase un minuto. Continúa con seguridad y vuelve a consultar cuando haya transcurrido tiempo:

```
docker compose exec -T mongo-indices mongosh --quiet --file /lab/07_ver_ttl.js
```

El monitor TTL actúa en segundo plano; no garantiza supresión exacta al llegar el reloj a cero. Para explicar el matiz, diferencia *fecha elegible para eliminación* de *eliminación ya ejecutada*.

7. Las tres pruebas de seguridad que deben verse en directo

Prueba 1: anónimo sin permisos

```
docker compose exec -T mongo-seguridad mongosh --quiet --eval 'db.getSiblingDB("curso_seguridad").secretos.findOne()'
```

El proceso puede abrir una conexión, pero leer la colección protegida debe ser rechazado. Lo que importa es el error de autorización en la operación, no si se mostró el banner de `mongosh`.

Prueba 2: lector autenticado

```
docker compose exec -T mongo-seguridad sh -lc 'mongosh --quiet -u lectorlab -p "$LAB_READER_PASSWORD" --
authenticationDatabase curso_seguridad --eval "db.getSiblingDB("curso_seguridad").secretos.findOne()"'
```

Ahora la consulta debe devolver el documento sintético. Este éxito permite interpretar la siguiente denegación como **autorización**, no como caída de servidor.

Prueba 3: el mismo lector intenta escribir

```
docker compose exec -T mongo-seguridad sh -lc 'mongosh --quiet -u lectorlab -p "$LAB_READER_PASSWORD" --
authenticationDatabase curso_seguridad --file /lab/09_comprobar_readonly.js'
```

El script intenta una inserción y espera código 13 / `Unauthorized`; si se concedieron permisos de más, lanza una excepción. En el examen final, pedir al alumno que explique por qué `Authentication failed` y `Unauthorized` no significan lo mismo.

8. Actividad opcional de TLS y autenticación X.509 real

Esta demostración está verificada en GitHub Actions con MongoDB Community 8.0. No es necesario usar Enterprise para la autenticación X.509 de clientes. La ampliación requiere Bash (Git Bash o WSL en Windows), OpenSSL y Docker; no forma parte del itinerario imprescindible de 180 minutos.

Preparación en un directorio recién clonado del repositorio (sin certificados anteriores):

```
cp .env.example .env            # en PowerShell: Copy-Item .env.example .env
# Editar .env para asignar contraseñas exclusivamente docentes.
bash scripts/generar-certificados.sh
docker compose up -d --wait mongo-seguridad mongo-tls
```

Para ejecutar **la prueba integral, incluida la creación del usuario $external**, Bash debe disponer de las contraseñas de `.env` como variables de entorno:

```
set -a
. ./.env
set +a
bash scripts/probar-seguridad.sh
```

El script comprueba, en orden, que SCRAM rechaza la conexión anónima y las contraseñas erróneas; que `read` autoriza la lectura y niega la escritura; que TLS rechaza el canal sin cifrar; y que un certificado X.509 con un usuario en `$external` puede leer, pero no insertar. **La comparación se considera probada solo si el script termina con `[OK] BANCO DE SEGURIDAD COMPLETO`.**

Para inspeccionar las partes públicas de los certificados (nunca publiques los `.key` ni los `.pem` que incluyen clave privada):

```
openssl x509 -in certs/server.crt -noout -subject -issuer -dates -ext subjectAltName
openssl x509 -in certs/client.crt -noout -subject -issuer -dates
```

La secuencia se reproduce también desde GitHub Actions, sin instalación local de MongoDB. No se utilizan certificados empresariales ni secretos permanentes.

9. LDAP, cifrado en reposo y límites de la demo

LDAP: MongoDB Enterprise puede integrarse con directorios; a partir de 8.0 la autenticación/autorización LDAP está obsoleta y se anuncia su retirada futura. La actividad consiste en dibujar cliente → MongoDB → directorio → grupo → rol y discutir alternativas. La instalación de LDAP no se ha realizado ni se considera una demostración en Community.

Cifrado en reposo: el motor WiredTiger cifrado autogestionado es una capacidad Enterprise. El volumen de Docker sin medidas adicionales no demuestra esta protección. Separar cifrado del disco/almacenamiento, cifrado nativo del motor y cifrado del lado cliente; asociar cada uno a custodio de claves, amenaza y recuperación.

TLS: un canal cifrado protege tránsito, pero no concede permisos por sí mismo ni cifra todos los ficheros. **X.509:** el certificado de cliente debe vincular su sujeto a un usuario con roles en `$external`. **SCRAM:** autentica pero no equivale a TLS.

10. Diagnóstico rápido de errores de aula

Síntoma	Pregunta correcta	Medida concreta
`docker: command not found`	¿Docker instalado?	Instalar e iniciar Docker Desktop
`Cannot connect to Docker daemon`	¿Está arrancado Engine?	Abrir Docker Desktop y esperar inicialización
`port is already allocated`		

Síntoma	Pregunta correcta	Medida concreta
	¿Existe MongoDB local u otro contenedor?	Inspeccionar puerto y ajustar mapeo de host, no el puerto interno
`Authentication failed`	¿Cuenta, clave y authSource?	Contrastar `adminlab@admin` frente a `lectorlab@curso_seguridad`
`Unauthorized`	¿Identidad válida sin privilegios?	Probar antes una lectura permitida
El lector no existe	¿Se ejecutó script 08?	Preparar demo con cuenta root, revisar volumen
`COLLSCAN` después de crear índices	¿Filtro y nombre de índice?	Ver `getIndexes()` y repetir el mismo predicado
`IndexNotFound`	¿Se ejecutó el script de índices?	Crear clave concreta; no cambiar diez cosas a la vez
TTL no borra inmediatamente	¿Es BSON Date? ¿Ya es elegible?	Comprobar timestamp y esperar monitor
Certificado no válido	¿CA, SAN, expiración, subject?	Regenerar certificados de laboratorio y registrar identidad exacta

11. Criterios de evaluación

La evaluación comprueba la *explicación causal*, no la cantidad de comandos copiados. Pide dos evidencias de índices (antes y después de una consulta), una explicación de prefijos compuestos, una captura interpretada de $text o TTL y una comparación de seguridad con permiso permitido y denegado. Una respuesta completa nombra índice o usuario, escenario inicial, resultado real, hipótesis que queda confirmada y limitación. No se puntúa como realizada una prueba de LDAP ni de cifrado Enterprise que solamente se ha explicado.

12. Parada, limpieza y siguiente sesión

Para detener contenedores sin destruir los datos persistidos:

```
docker compose down
```

No uses `docker compose down -v` salvo decisión explícita de destruir todos los volúmenes sintéticos del laboratorio. Para la siguiente clase, evita resetear la colección de ventas si quieres conservar las comparaciones o ejecuta la carga en el orden previsto.

13. Documentación oficial

- Tipos de índices v8.0
- Índices compuestos y prefijos
- Resultados de explain
- Índices TTL
- TLS v8.0
- Clientes X.509
- LDAP v8.0 — obsoleto
- Cifrado en reposo